

DEEP ASSURANCE v6

ERC-20 Rehearsal Audit

BasicERC20RehearsalV1

PASS

completionStatus: COMPLETE

Exact source: CurveYield/Contracts @ 248e5d5de42f8a111050fb8d2b7d587653833331

Environment: Ethereum fork - block 20,000,000

Date: August 6, 2026

Prepared for CurveYield

Point-in-time AI-generated security assessment. No OpenZeppelin affiliation or certification.

Table of Contents

Important Notice and Engagement Metadata	3
Executive Summary	4
Exact Source	5
Scope	5
Methodology and Assurance Boundaries	6
System Overview	7
Security Considerations and Threat Model	7
Findings Summary	8
Notes & Additional Information	8
Remediation Review	9
Phase Results	10
Lane Results	11
Findings / Error Records / Limitations	12
Evidence Index	14
Conclusion	15
Final Delivery Packet and Validation	16

Publication Artifact Revision v3

Authoritative audit decisions remain frozen under report ID deep-assurance-v16-2-erc20-rehearsal-report-v1.

Publication v3 is generated and committed inside GitHub to preserve exact binary bytes after rejected connector binary transports.

Frozen Markdown v1 remains authoritative. The PDF content is rendered from that unchanged Markdown.

Important Notice and Engagement Metadata

This is a point-in-time AI-generated security assessment of a purpose-built ERC-20 rehearsal fixture. It uses an OpenZeppelin-inspired report organization but is not issued, endorsed, reviewed, or certified by OpenZeppelin. An audit improves assurance but cannot guarantee the absence of defects.

The user explicitly required a no-poll rehearsal. Accordingly, the poll/task bootstrap, scheduled liveness, and cross-chat wake/failover mechanics required by a production Deep Assurance campaign were intentionally not executed and are not represented as passed. All numbered agent roles, Agent 0, Agent 7, the Orchestrator, and the controller-owned final-report coordinator were executed serially by this ChatGPT / GPT-5.6 Thinking runtime. Separate-review boundaries were enforced procedurally through distinct immutable submissions and review records, but they do not constitute independent model or independent human review.

No dependencies were downloaded locally and no Solidity compilation occurred locally. Compilation and fork execution occurred only in the trusted GitHub Actions runner. No production deployment or public transaction broadcast was performed.

Table of Contents

The PDF version contains an automatically generated page-numbered table of contents.

Executive Summary

The rehearsal completed the Deep Assurance v16.2 phase sequence against BasicERC20RehearsalV1, a dependency-free fixed-supply ERC-20 fixture created specifically for this process test. The exact source was frozen at commit 248e5d5de42f8a111050fb8d2b7d587653833331. Manual scope, architecture, implementation, and economic-accounting lanes found no material security defect. GitHub-native compilation completed with solc 0.8.28 and zero compiler diagnostics. A GitHub-hosted Ethereum fork simulation at exact block 20,000,000 executed 24 of 24 lifecycle checks with zero failed steps and 262 archive-backed RPC requests with zero RPC failures.

The final validated issue inventory contains 0 Critical, 0 High, 0 Medium, 0 Low, and 2 Notes. The notes concern the conventional ERC-20 allowance replacement race and a zero-value transferFrom event-semantics edge case. Neither creates unauthorized value, changes total supply, bypasses allowance, or establishes a launch blocker for this fixture. No source remediation was supplied or required.

Overall security posture: PASS for the exact rehearsal fixture and exercised evidence.

completionStatus: COMPLETE

securityVerdict: PASS

Unresolved launch blockers: 0

The strongest properties observed were fixed immutable supply, absence of privileged control paths, absence of external calls/reentrancy edges, direct balance-conservation logic, finite allowance checks, and execution-backed confirmation of the infinite-allowance and self-transfer branches.

This PASS is not a certification of the Deep Assurance production orchestration layer because poll/task automation and true independent agent runtimes were intentionally omitted by request. It is also not a production deployment audit because the reviewed contract is an inert rehearsal fixture.

Exact Source

- Repository: CurveYield/Contracts
- Commit: 248e5d5de42f8a111050fb8d2b7d587653833331
- Project path: audit-fixtures/deep-assurance-v16-2-erc20
- In-scope file: BasicERC20Rehearsal_v1.sol
- Git blob SHA: 0527d19901a07a12911f3a212ee2664df8219afc
- Source file SHA-256: 45f03e840b749f0d34255402aacc3045a51dede8c6a08cafc7a83242c7c9ee9c
- Original source ZIP: Not applicable; the fixture was created directly as a dedicated GitHub rehearsal source.
- Controller release: CurveYield/audit-controller@d09a925d4735da8acde24baf39a1de2fb90ddd2f
- Skill release: ai-auditor-deep-assurance-v6@16.2.0
- Runner release: deep-assurance-github-bridge-v1
- Runner manifest SHA-256: 51fc7ef486a75a0593aaf9f8b54965424785e34198479f4ee74dd88168f53292
- Frozen finalization snapshot SHA-256: c5a86a09fcd9ae74ebcd0ccf618b7f45ee6b756c5197b47fcd3c6ccdbe7305

Scope

In Scope

- Full-file review of BasicERC20Rehearsal_v1.sol.
- Constructor supply assignment and mint-style event.
- transfer, approve, transferFrom, and _transfer state transitions.
- totalSupply, balanceOf, and allowance accounting.
- Zero-address behavior, zero-value behavior, same-address transfer behavior, finite allowance decrement, maximum allowance persistence, and revert atomicity.
- GitHub-native exact-source compile evidence.
- GitHub-native Ethereum fork lifecycle evidence.

Out of Scope

- Production deployments and deployed-bytecode equivalence.

- Any other CurveYield contract or repository path.
- Frontend, governance, keeper, bridge, oracle, database, or off-chain infrastructure.
- Poll/task automation, scheduled liveness, cross-chat wakeups, and real multi-agent concurrency, by explicit user instruction.
- Public transaction broadcast or signing with a production wallet.

Dependencies and Integrations

The reviewed source has no Solidity imports and makes no external calls. OpenZeppelin 5.4.0 was pinned in the trusted runner request contract because the runner schema requires an exact dependency release identity; the fixture does not import it.

Methodology and Assurance Boundaries

The rehearsal executed the ten Deep Assurance phases in sequence and exercised the required role responsibilities as serial, immutable GitHub submissions. The four first-pass clean-room roles separately covered scope/specification, architecture/threat modeling, implementation, and economic/accounting analysis. Agent 7 then challenged and accepted those submissions. Agent 5 dispatched two exact-source GitHub-native technical profiles, and their artifacts were downloaded and hash-verified before their gates were accepted. Agent 6 performed adversarial falsification and finding/severity reconciliation after technical evidence was available. Agent 7 independently reviewed the findings and the Phase 9 disposition. Agent 0 exercised durable-state failover readiness without fabricating a takeover. The controller-owned final-report coordinator froze the prepublication snapshot, and Agent 7 accepted it before report generation.

The compile request and simulation request were strict, atomic GitHub request files. Commit status was used only for navigation; acceptance relied on workflow job topology, expected skipped branches, exact source checkout, normalized result bundles, artifact manifests, recomputed hashes, tool versions, and per-step results.

The no-poll rehearsal override materially limits conclusions about unattended production orchestration. Likewise, all role simulations used one underlying model runtime, so procedural reviewer separation is weaker than independent personnel or independently instantiated models.

System Overview

BasicERC20RehearsalV1 is a fixed-supply token contract with no administrator, proxy, upgrade mechanism, fee logic, external integrations, mint function, burn function, pause function, blacklist, or callback. At construction, the immutable totalSupply is set to initialSupply, the deployer receives the full balance, and a conventional Transfer(address(0), deployer, initialSupply) event is emitted.

A holder can transfer tokens to any nonzero recipient. A holder can approve a nonzero spender for an exact allowance. An approved spender can transfer tokens from the owner's balance while consuming a finite allowance. An allowance equal to type(uint256).max is intentionally treated as non-decrementing infinite approval. All token balance movement occurs inside _transfer, which rejects the zero recipient and checks the source balance before entering a small unchecked arithmetic region.

Because no operation can increase totalSupply, aggregate balances are conserved by reachable state transitions. There is no external call or user-supplied callback between state changes, eliminating the reviewed contract's reentrancy surface.

Security Considerations and Threat Model

Actors and Authority

The deployer is only the initial token holder; deployment grants no administrative capability. Token holders control their own transfers and approvals. Approved spenders can move only the owner's tokens within the recorded allowance. There are no trusted keepers, governors, or privileged emergency actors.

Assets and Invariants

The sole asset is the DART accounting balance. The primary invariant is $\text{sum}(\text{balanceOf}) == \text{totalSupply}$, with totalSupply immutable after construction. Successful transfers must move exactly the requested amount without creating or destroying units. Finite allowances must not underflow and maximum allowance must remain unchanged after use. Failed operations must revert atomically.

Attack Surfaces Reviewed

The audit challenged unauthorized transfer, supply creation, balance overflow/underflow, self-transfer inflation, allowance bypass, finite allowance underflow, failed-transfer partial state, zero-address misuse, reentrancy, privilege escalation, and upgradeability. No material attack path survived validation.

Severity Model

Critical, High, and Medium findings are launch blockers under Deep Assurance absent authorized resolution or risk acceptance. Low findings do not automatically block launch. Notes describe useful non-material behavior and do not inflate the formal security defect count.

Findings Summary

Class | Count | Unresolved security defects

Critical | 0 | 0

High | 0 | 0

Medium | 0 | 0

Low | 0 | 0

Notes | 2 | 0

Client-Reported | 0 | 0

ID | Title | Class | Status | Affected component | PDF page

N-01 | Standard ERC-20 allowance replacement race | Note | Acknowledged / non-material | `approve` interface | 8

N-02 | Zero-value transferFrom may use zero-address source | Note | Acknowledged / non-material | `transferFrom`, `\_transfer` | 8

Critical, High, and Medium Summary

There are no Critical, High, or Medium findings. No unresolved launch blocker was identified for the exact rehearsal fixture.

Detailed Findings

No Critical, High, Medium, or Low source-specific security findings were validated.

Notes & Additional Information

N-01 - Standard ERC-20 allowance replacement race

Class: Note

Status: Acknowledged, not a source-specific security defect

An owner changing an already nonzero allowance directly to another nonzero value retains the conventional ERC-20 approval race: a spender can potentially consume the old allowance before the replacement transaction lands and then receive the newly written allowance. The reviewed implementation does not allow a spender to bypass the stored allowance and does not introduce a source-specific variant beyond standard approve replacement semantics.

Evidence: Manual implementation review, architecture/threat review, Agent 6 adversarial validation, and the accepted finite/infinite allowance fork lifecycle.

Recommendation: Integrator or UI flows may use a zero-first allowance replacement pattern where appropriate. Optional allowance-adjustment helper functions could be added in a future design for UX hardening.

N-02 - Zero-value transferFrom may use zero-address source

Class: Note

Status: Acknowledged, not a security defect

transferFrom(address(0), nonzeroRecipient, 0) can complete because zero allowance and zero balance both satisfy the ≥ 0 checks and `_transfer` only rejects a zero recipient. The hosted fork simulation reproduced this behavior and confirmed that the recipient received no tokens and final totalSupply remained unchanged. The consequence is limited to strict event/indexing semantics because a zero-value Transfer can have address zero as its source without representing a mint.

Evidence: GitHub Actions simulation run 31135160334, lifecycle steps 22-24.

Recommendation: If strict zero-address transfer-event semantics are desired, explicitly reject from `== address(0)` in `_transfer` or `transferFrom`. No security remediation is required for this report's verdict.

Client-Reported Issues

None.

Recommendations

R-01 - Integrator allowance UX

Where nonzero allowances are replaced, use an allowance-management flow that makes the conventional ERC-20 replacement race explicit to users or employs zero-first replacement where operationally appropriate.

R-02 - Optional strict zero-address semantics

If downstream analytics treat every Transfer from address zero as a mint signal, consider explicitly rejecting a zero from address even for zero-value transferFrom calls.

Remediation Review

No Critical, High, Medium, or Low findings required remediation. No source change was proposed or applied after accepted execution evidence. Phase 9 therefore concluded with NO_REMEDIATION_SUPPLIED and no unresolved launch blocker. Agent 7 independently accepted that disposition.

Phase Results

Phase | Gate | Status | Client-readable outcome

- 1 | exact-scope-provenance-complete | PASS | Exact GitHub source revision and single-file scope frozen and fetched back.
- 2 | risk-specification-complete | PASS | Actors, assets, invariants, intended behavior, negative requirements, and review priorities defined.
- 3 | architecture-threat-model-complete | PASS | No privilege, external-call, upgrade, or material attack-path defect identified.
- 4 | manual-implementation-review-complete | PASS | Full-file state-transition review found no validated security defect.
- 5 | economic-mathematical-review-complete | PASS | Fixed-supply conservation, bounds, allowance accounting, and zero/max edges reconciled.
- 6 | exact-build-and-tests-complete | PASS | GitHub-native compile passed with solc 0.8.28, zero diagnostics, artifact hashes verified.
- 7 | fork-simulation-lifecycle-complete | PASS | Ethereum block 20,000,000 fork; 24/24 lifecycle steps completed; 0 RPC failures.
- 8 | findings-validation-complete | PASS | 0 C/H/M/L; 2 Notes; candidate false positives rejected with source and execution evidence.
- 9 | remediation-review-complete | PASS | No formal finding required remediation; no blocker remained.
- 10 | release-and-report-complete | PENDING AT REPORT FREEZE | Must remain pending until publication record is accepted, then becomes PASS before user delivery.

Lane Results

Role ID | Status | Primary evidence

scope-specification-auditor | ACCEPTED | Agent 1 scope/specification submission v1
architecture-threat-auditor | ACCEPTED | Agent 2 architecture/threat submission v1
manual-implementation-auditor | ACCEPTED | Agent 3 implementation submission v1
economic-accounting-auditor | ACCEPTED | Agent 4 economic/accounting submission v1
build-simulation-evidence-auditor | ACCEPTED | GitHub-native compile and fork evidence submissions v1
adversarial-no-go-auditor | ACCEPTED | Agent 6 adversarial submission v2
final-report-coordinator | ACCEPTED | Finalization input snapshot v1 + Agent 7 review

Findings

```
[
{
  "id": "NOTE-01",
  "class": "NOTE",
  "severity": "INFORMATIONAL",
  "status": "ACKNOWLEDGED_NON_MATERIAL",
  "title": "Standard ERC-20 allowance replacement race",
  "affectedComponent": "approve",
  "remediationState": "NO_REMEDIATION_SUPPLIED"
},
{
  "id": "NOTE-02",
  "class": "NOTE",
  "severity": "INFORMATIONAL",
  "status": "ACKNOWLEDGED_NON_MATERIAL",
  "title": "Zero-value transferFrom may use zero-address source",
  "affectedComponent": "transferFrom/_transfer",
  "remediationState": "NO_REMEDIATION_SUPPLIED"
}
]
```

General Errors

```
[ ]
```

No material general error affected the accepted security evidence. An early read of the compile request commit returned no published status before GitHub had attached the Actions context; the workflow was later resolved through its run identity and accepted only after terminal artifact verification. This was a transient observation, not a failed process.

Process-Stopping Errors

```
[ ]
```

No process-stopping error occurred in the restarted v16.2 rehearsal.

Non-Completed Processes

```
[
{
  "process": "poll/task bootstrap and scheduled liveness",
  "reason": "explicit operator instruction to run the rehearsal without polls",
  "affectedGate": "production Phase 0 only",
  "downstreamConsequence": "no claim that production unattended orchestration, task wakeup, or poll failover was proven",
  "futureAction": "run a separate production-orchestration rehearsal if poll behavior itself must be validated"
},
{
  "process": "true independent multi-agent execution",
  "reason": "the operator requested one ChatGPT runtime to execute every role",
  "affectedGate": "review-independence assurance boundary",
  "downstreamConsequence": "separate review was procedural rather than independent-model or independent-human review",
  "futureAction": "use separate clean-room runtimes when validating independence itself"
}
]
```

Limitations

```
[
{
  "id": "limitation-no-polls-v1",
  "type": "environment/process",
  "effect": "Rehearsal only; production poll/task orchestration was intentionally not exercised."
},
{
  "id": "limitation-single-runtime-agent-simulation-v1",
  "type": "review independence",
  "effect": "All roles were executed serially by one model runtime."
},
{
  "id": "limitation-purpose-built-fixture-v1",
  "type": "scope",
  "effect": "The source is a purpose-built ERC-20 fixture rather than a production protocol."
},
{
  "id": "limitation-no-production-deployment-v1",
  "type": "deployment applicability",
  "effect": "No deployed-bytecode equivalence, production configuration, or public transaction was reviewed."
},
{
  "id": "limitation-rpc-health-persistence-disabled-v1",
  "type": "execution environment",
  "effect": "Cross-session RPC health persistence was disabled, although the accepted run completed 262 requests with zero failures."
}
]
```


Evidence Index

- Source manifest: audit-controller/rehearsals/deep-assurance-v16-2-erc20-v1/source/EXACT_SOURCE_MANIFEST_v1.json
- Decision registry:
audit-controller/rehearsals/deep-assurance-v16-2-erc20-v1/finalization/FINALIZATION_DECISION_REGISTRY_v1.json
- Finalization snapshot:
audit-controller/rehearsals/deep-assurance-v16-2-erc20-v1/finalization/FINALIZATION_INPUT_SNAPSHOT_v1.json
- Snapshot digest: c5a86a09fcdf9ae74ebcd0ccf618b7f45ee6b756c5197b47fdb3c6ccdbe7305
- Compile request: dar-880b1c8d2857ae959cfd44da875d63d6
- Compile request digest: 880b1c8d2857ae959cfd44da875d63d68edfa6831bc00ff2f1f6451969f5f3c2
- Compile Actions run: 31134852492
- Compile artifact ID: 8977524095
- Compile artifact ZIP SHA-256: 62fa7e92788931a570704d8422b160a01d196b0876442f651a8f420327db736e
- Simulation request: dar-f5d9589d7c0a87a40de563b3c79c463b
- Simulation request digest: f5d9589d7c0a87a40de563b3c79c463b1d15e2f10d556a11b9d25bc28659943b
- Simulation Actions run: 31135160334
- Simulation artifact ID: 8977655037
- Simulation artifact ZIP SHA-256: 4fd3fe33bb8d5186a2498fc6deb5c2f7ccc650990e85b06ac3041456f9a55d2e
- Fork block: 20000000
- Fork block hash: 0xd24fd73f794058a3807db926d8898c6481e902b7edb91ce0d479d6760f276183
- Fork engine: hardhat-edr@3.12.0
- Compiler: solc 0.8.28

The supporting archive contains the normalized compile/simulation results, source manifests, artifact manifests, decision/finalization records, and client-facing report artifacts.

Release Manifest

Publication packet path:

CurveYield/Audits/deep-assurance-v16-2-erc20-rehearsal-v1/FINAL_AUDIT_PACKET_v1/

Planned immutable packet records:

- RELEASE_MANIFEST_v1.json
- ARTIFACT_DIGEST_RECEIPT_v1.json
- PUBLICATION_MANIFEST_v1.json
- PUBLICATION_MANIFEST_FETCHBACK_RECEIPT_v1.json
- FINAL_USER_DELIVERY_RECEIPT_v1.json

At this Markdown freeze point, source drift is false, all seven lanes are accepted, Phases 1-9 are PASS, and Phase 10 is the sole pending gate. The external artifact digest receipt and publication fetch-back receipt are generated only after the Markdown, PDF, and supporting archive bytes are final.

Conclusion

The exact BasicERC20RehearsalV1 source reviewed in this campaign has a small attack surface and straightforward accounting. No Critical, High, Medium, or Low source-specific security defect was validated. The hosted compiler accepted the exact source without diagnostics, and the archive-backed Ethereum fork executed all 24 lifecycle assertions successfully, including finite and infinite allowance behavior, revert atomicity, self-transfer conservation, and the zero-value zero-source edge. Two non-material notes remain for allowance UX and strict event semantics.

For this exact purpose-built fixture and the evidence actually executed, the security verdict is PASS. No formal remediation or risk acceptance is required. This result does not certify poll/task orchestration, true independent agent review, production deployment configuration, or any other CurveYield contract. As with any audit, the assessment cannot guarantee absence of vulnerabilities outside the reviewed scope or evidence.

Appendices

Appendix A - Severity Definitions

- Critical: direct catastrophic loss, systemic compromise, or equivalent impact with practical exploitability.
- High: major loss or privilege compromise with substantial impact.
- Medium: material security defect requiring remediation or explicit authorized risk acceptance.
- Low: limited-impact defect not normally launch-blocking alone.
- Note: useful non-material observation or compatibility/operational consideration.

Appendix B - Fork Lifecycle Summary

The accepted simulation deployed an ephemeral copy at 0xeA8AE08513f8230cAA8d031D28cB4Ac8CE720c68 inside the isolated fork only. It did not broadcast a public transaction and has no production significance.

Final Delivery Packet

- Markdown report: Deep_Assurance_v16_2_ERC20_Rehearsal_Final_Report_v1.md
- PDF report: Deep_Assurance_v16_2_ERC20_Rehearsal_Final_Report_v1.pdf
- Supporting archive: Deep_Assurance_v16_2_ERC20_Rehearsal_Supporting_Files_v1.zip
- Evidence index: EVIDENCE_INDEX_v1.json
- Error/process records: GENERAL_ERRORS_v1.json, PROCESS_STOPPING_ERRORS_v1.json, NON_COMPLETED_PROCESSES_v1.json
- Release manifest: RELEASE_MANIFEST_v1.json
- External artifact digest receipt: ARTIFACT_DIGEST_RECEIPT_v1.json
- Publication manifest: PUBLICATION_MANIFEST_v1.json
- Publication fetch-back receipt: PUBLICATION_MANIFEST_FETCHBACK_RECEIPT_v1.json

Completion Status

completionStatus: COMPLETE

Security Verdict

securityVerdict: PASS

Final Artifact Validation

- FINAL_PDF_VALIDATED: pending until PDF render/text reconciliation
- PDF page count: pending
- Page-render QA result: pending
- Binary upload commit: pending
- Fetch-back hash equality: pending
- External artifact digest receipt: ARTIFACT_DIGEST_RECEIPT_v1.json
- Publication manifest fetch-back receipt: PUBLICATION_MANIFEST_FETCHBACK_RECEIPT_v1.json
- Final user delivery receipt: FINAL_USER_DELIVERY_RECEIPT_v1.json

These validation states are externally recorded after the report bytes are final; they are not back-filled into this authoritative Markdown in order to preserve the acyclic publication graph.

Frozen Finalization Sets

- reportId: deep-assurance-v16-2-erc20-rehearsal-report-v1
- finalizationSnapshotSha256: c5a86a09fcdf9ae74ebcd0ccf618b7f45ee6b756c5197b47fcd3c6ccdbe7305
- reportCompletionStatus: COMPLETE
- securityVerdict: PASS
- submissionAdmissionIds: admission-agent-1-scope-v1, admission-agent-2-architecture-v1, admission-agent-3-manual-v1, admission-agent-4-economic-v1, admission-agent-5-compile-v1, admission-agent-5-simulation-v1, admission-agent-6-adversarial-v2, admission-final-report-coordinator-v1
- independentReviewIds: review-first-pass-agent-7-v1, review-compile-agent-7-v1, review-simulation-agent-7-v1, review-findings-agent-7-v1, review-remediation-agent-7-v1, review-finalization-snapshot-agent-7-v1
- claimDispositionIds: claim-allowance-replacement-race, claim-zero-value-zero-source-transfer, claim-unchecked-recipient-overflow, claim-self-transfer-inflation, claim-reentrancy, claim-privilege-escalation, claim-supply-inflation, claim-finite-allowance-bypass, claim-failed-transfer-retains-allowance-decrement
- canonicalFindingIds: NOTE-01, NOTE-02
- severityDecisionIds: severity-NOTE-01-v1, severity-NOTE-02-v1
- evidenceDispositionIds: evidence-exact-source-v1, evidence-first-pass-analysis-v1, evidence-github-native-compile-v1, evidence-github-native-simulation-v1
- remediationDecisionIds: remediation-no-formal-findings-v1
- limitationDecisionIds: limitation-no-polls-v1, limitation-single-runtime-agent-simulation-v1, limitation-purpose-built-fixture-v1, limitation-no-production-deployment-v1, limitation-rpc-health-persistence-disabled-v1
- exactSetEqualityVerified: true
- PDF_CONTENT_BINDING result: pending external validation receipt
- publicationManifestFetchbackVerified: pending external validation receipt